



Augmented Cyber Risk Analysis

Rapport de contre-audit de sécurité du code source

Findings, correctifs appliqués et risques résiduels

Application	ACRA — EBIOS RM (Next.js 16 / Prisma / next-auth)
Périmètre	ebios-rm/src — ~27 700 lignes (TypeScript)
Référentiels	OWASP Top 10 2021 · CWE Top 25 · patterns SAST · OWASP LLM
Date du rapport	12 juin 2026
Type	Contre-audit (audit initial + correctifs vérifiés)
Validation	189 tests unitaires — 100 % au vert · 0 erreur TypeScript

Score de risque global : 4,6 / 10 — MOYEN

1. Résumé exécutif

Ce rapport de contre-audit fait suite à l'audit statique du code source d'ACRA. Il consolide les vulnérabilités identifiées, l'état des correctifs appliqués lors de la même session, et les risques résiduels nécessitant une décision ou une action d'exploitation.

La base de code est globalement bien durcie (Prisma paramétré, bcrypt cost 12, contrôle d'accès cohérent, en-têtes/CSP solides). Les findings relèvent principalement d'*incohérences de durcissement* — un mécanisme sécurisé à un endroit, oublié sur son jumeau — plutôt que de failles béantes.

1 HIGH	4 MEDIUM	2 LOW	5 corrigés/atténués
--------	----------	-------	---------------------

Sur 7 findings, 5 ont été corrigés ou atténués et vérifiés par des tests ; 2 relèvent de l'exploitation/configuration et 1 a été explicitement accepté par l'exploitant.

ID	Vulnérabilité	Sévérité	CVSS	Statut
F002	Injection de formule CSV — export du journal d'audit	HIGH	6.5	CORRIGÉ
F005	Secrets SSO / SMS stockés (et journalisés) en clair	MEDIUM	5.5	CORRIGÉ
F003	Anti-brute-force / rate-limiting contournable	MEDIUM	5.3	À TRAITER (ops)
F006	Assignment de masse partielle (sauvegarde des ateliers)	LOW	4.3	CORRIGÉ
F007	Injection de prompt (suggestions IA)	LOW	3.5	ATTÉNUÉ
F001	Secrets réels dupliqués dans la sortie de build	MEDIUM	5.5	À TRAITER (ops)
F004	Inscription anonyme ouverte + premier compte ADMIN	MEDIUM	6.5	RISQUE ACCEPTÉ

2. Méthodologie

Analyse statique du code source combinant cartographie de la surface d'attaque (points d'entrée API, authentification, gestion des secrets, couche de données) et revue ciblée des fichiers sensibles.

Référentiels : OWASP Top 10 2021, CWE Top 25, patterns SAST (injection, secrets, crypto faible, mass assignment) et OWASP LLM pour la fonctionnalité IA.

Scoring : CVSS 3.1 estimé par finding. Méthode de correction : TDD conforme aux règles du dépôt (test d'abord, implémentation, vérification npm test au vert).

Périmètre : application ebios-rm (~27 700 lignes TypeScript). Exclusions : tests d'intrusion dynamiques, revue d'infrastructure, audit des dépendances tierces (CVE) hors périmètre statique.

3. Findings détaillés

Les findings sont présentés par sévérité décroissante. Le statut indique l'état à l'issue de la session de remédiation.

F002 — Injection de formule CSV — export du journal d'audit

Sévérité	HIGH — CVSS 6.5	Statut	CORRIGÉ
CWE	CWE-1236	OWASP	A03:2021
Fichier(s)	src/app/api/admin/audit-log/export/route.ts		

Observation. La fonction `escapeCsv` n'échappait que les guillemets, virgules et sauts de ligne, sans neutraliser les déclencheurs de formule (= + - @ TAB CR). Les champs `userEmail` / `détails` provenant d'entrées attaquant (ex. inscription avec un email `"=cmd|'/C calc '!A1'"`), un ADMIN ouvrant le CSV dans Excel/LibreOffice déclenchait l'exécution de la formule.

Correctif appliqué. Création d'une primitive partagée et testée `toCsvCell()` (`sanitizeForSpreadsheet` + échappement RFC 4180) dans `src/lib/spreadsheet-safe.ts` ; la route l'utilise désormais. Même primitive que l'export d'analyse → durcissement cohérent. 4 tests ajoutés.

F005 — Secrets SSO / SMS stockés (et journalisés) en clair

Sévérité	MEDIUM — CVSS 5.5	Statut	CORRIGÉ
CWE	CWE-312 / CWE-532	OWASP	A02:2021
Fichier(s)	src/app/api/admin/sso-config/route.ts · .../password-policy/route.ts		

Observation. `oidcClientSecret`, `smsApiKey` et `smsApiSecret` étaient persistés en clair en base ; de plus le PUT `password-policy` journalisait ces secrets SMS en clair dans la table `AuditLog`.

Correctif appliqué. Nouveau module AES-256-GCM `src/lib/secret-crypto.ts` (chiffrement à l'écriture, déchiffrement transparent à la lecture, rétro-compatible avec les valeurs en clair existantes — sans migration de schéma). Secrets masqués avant journalisation via `src/lib/audit-redact.ts`. Clé via `SECRETS_ENCRYPTION_KEY` (repli `NEXTAUTH_SECRET`). 10 tests ajoutés (crypto + redaction).

F003 — Anti-brute-force / rate-limiting contournable

Sévérité	MEDIUM — CVSS 5.3	Statut	À TRAITER (ops)
CWE	CWE-290 / CWE-307	OWASP	A07:2021

Fichier(s)	src/lib/logger.ts · src/lib/auth.ts · src/app/api/auth/register/route.ts
------------	--

Observation. L'IP provient de X-Forwarded-For (falsifiable) → contournement des limites par IP et empoisonnement de l'audit trail. Le rate-limit de login est par email uniquement (pas d'IP). Les stores rate-limit et lockout sont in-memory (non distribués).

Recommandation. Annoté dans le code. Correctif en grande partie ops/config : dépend de la topologie de proxy de confiance (quel hop) et nécessite un store Redis en multi-instance. À cadrer selon le déploiement.

F006 — Assignment de masse partielle (sauvegarde des ateliers)

Sévérité	LOW — CVSS 4.3	Statut	CORRIGÉ
CWE	CWE-915	OWASP	A08:2021
Fichier(s)	src/app/api/analyses/[id]/workshop/[num]/route.ts		

Observation. Les ateliers A2/A3/A4 retiraient quelques champs UI puis passaient le reste de l'objet client à Prisma (spread ...rest), contrairement à A5 et à l'import qui appliquent une allowlist. Impact borné (Prisma rejette les champs inconnus) mais durcissement incohérent.

Correctif appliqué. Extraction d'un module allowlist src/lib/workshop-sanitize.ts (champs du schéma uniquement, typés et bornés) appliqué à A2/A3/A4. Test réécrit pour importer le vrai module + cas de mass-assignment rejetée. 12 tests.

F007 — Injection de prompt (suggestions IA)

Sévérité	LOW — CVSS 3.5	Statut	ATTÉNUÉ
CWE	CWE-1427	OWASP	LLM01
Fichier(s)	src/app/api/ai-suggest/route.ts		

Observation. contexte et question (contrôlés par l'utilisateur) étaient interpolés directement dans le prompt envoyé au modèle, permettant un détournement ("ignore les instructions...") ou un gaspillage de budget. Impact limité (réponse au même utilisateur, tailles bornées, rate-limit IA).

Correctif appliqué. Données utilisateur sorties du system prompt et placées dans des blocs balisés <contexte_organisation>/<question_analyste>, avec une règle explicite instruisant le modèle de traiter ces blocs comme des données et jamais comme des instructions.

F001 — Secrets réels dupliqués dans la sortie de build

Sévérité	MEDIUM — CVSS 5.5	Statut	À TRAITER (ops)
CWE	CWE-200 / CWE-538	OWASP	A05:2021
Fichier(s)	.next/standalone/ebios-rm/.env (généré)		

Observation. Le fichier `.next/standalone/ebios-rm/.env` contient les vrais secrets en clair (NEXTAUTH_SECRET, mot de passe Postgres, ANTHROPIC_API_KEY). Atténuation confirmée : `.dockerignore` exclut `.env` et `.next` — l'image Docker ne les contient pas. Risque résiduel : déploiement manuel du dossier standalone, sauvegardes/partages du working tree.

Recommandation. Action ops : purger le `.env` de la sortie de build (post-build), n'injecter les secrets qu'à l'exécution, et faire tourner les 3 secrets s'ils ont pu fuir.

F004 — Inscription anonyme ouverte + premier compte ADMIN

Sévérité	MEDIUM — CVSS 6.5	Statut	RISQUE ACCEPTÉ
CWE	CWE-862 / CWE-269	OWASP	A01:2021
Fichier(s)	src/app/api/auth/register/route.ts		

Observation. Le endpoint d'inscription est public ; sur une base vide, le premier inscrit devient ADMIN (course à l'amorçage). N'importe quel anonyme peut créer un compte.

Recommandation. Risque accepté par l'exploitant (décision documentée). Annotation conservée dans le code comme trace. Recommandation maintenue : provisionner l'ADMIN initial hors-ligne et gater l'inscription si le contexte évolue.

4. Synthèse de la remédiation

Nouveaux modules testés	spreadsheet-safe.toCsvCell · audit-redact · secret-crypto (AES-256-GCM) · workshop-sanitize
Tests	De 180 à 189 tests unitaires — 100 % au vert (TDD : test d’abord, puis correctif)
Type checking	0 erreur TypeScript sur les fichiers modifiés
Migration DB	Aucune — chiffrement des secrets rétro-compatible (les valeurs en clair sont chiffrées au prochain enregistrement)
Variable d’env	SECRETS_ENCRYPTION_KEY documentée dans .env.example (repli NEXTAUTH_SECRET)

Risques résiduels

F003 (rate-limiting) — en grande partie ops/config : robustesse de l’IP selon la topologie de proxy de confiance, et store Redis requis en multi-instance.

F001 (secrets dans le build) — action d’exploitation : purge du .env de la sortie standalone et rotation des trois secrets.

F004 (inscription ouverte) — risque explicitement accepté par l’exploitant ; recommandation maintenue.

F005 (chiffrement) — corrigé pour les nouvelles écritures ; les éventuelles valeurs en clair existantes sont chiffrées au prochain enregistrement (re-sauvegarde admin recommandée).

5. Score de maturité sécurité

Axe	Score	Commentaire
Authentification	3 / 4	bcrypt cost 12, logout, expiration, suspension. Manque MFA effectif + anti-brute-force par IP (F003).
Protection des données	3 / 4	Hash fort, sanitisation export, secrets désormais chiffrés au repos (F005 corrigé).
Dépendances	2 / 4	Épinglées ; pas de SBOM / audit automatisé visible.
Configuration	3 / 4	En-têtes/CSP solides, .dockerignore correct ; reste F001 (ops) et F004 (accepté).
Journalisation	4 / 4	Audit trail structuré (Winston + DB) ; secrets désormais redactés.

SMS global : 3,0 / 4

6. Points positifs (defense-in-depth en place)

- Aucune injection SQL : tout passe par Prisma (requêtes paramétrées), recherche incluse.
- Authentification : bcrypt cost 12, session JWT 8 h, rafraîchissement du rôle/isActive à chaque requête, invalidation immédiate des comptes suspendus, cookies httpOnly + sameSite + secure.
- Contrôle d'accès / IDOR : permissions centralisées appliquées de façon cohérente sur les routes analyses/* et admin/*.
- En-têtes de sécurité : CSP solide (object-src none, frame-ancestors none, base-uri self, pas de unsafe-eval), X-Frame-Options DENY, HSTS en production, API no-store.
- Validation Zod, bornage de la taille des imports, audit trail structuré, .dockerignore correct.

7. Prochaines actions recommandées

1. F001 — purger le .env de .next/standalone et faire tourner les trois secrets (DB / NEXTAUTH / Anthropic).
2. F003 — définir la source d'IP de confiance (topologie proxy), ajouter une clé de rate-limit par IP au login, et un store Redis en multi-instance.
3. F005 — re-sauvegarder les configurations SSO/SMS existantes pour chiffrer d'éventuelles valeurs en clair héritées ; définir une SECRETS_ENCRYPTION_KEY dédiée.
4. Mettre en place un audit automatisé des dépendances (npm audit en CI) et un SBOM.

Annotations inline : chaque finding est tracé dans le code source via des commentaires AUDIT [Fxxx] (corrigé/atténué/accepté), et un index complet est disponible dans `audit-annotations/FINDINGS_INDEX.md`.